



SPECYFIKACJA SYSTEMU LOGOWANIA

Aplikacja Compass

Wersja 1.0 | Luty 2026

Dokument poufny - wyłącznie do użytku wewnętrznego B2B.net S.A.

1. Wprowadzenie

Niniejszy dokument stanowi kompletną specyfikację systemu uwierzytelniania i autoryzacji dla aplikacji Compass, wewnętrznego narzędzia B2B.net S.A. Specyfikacja obejmuje model ról, mechanizmy bezpieczeństwa, zarządzanie cyklem życia kont oraz wymagania audytowe.

Dokument jest przeznaczony dla zespołu deweloperskiego jako podstawa do wyceny i implementacji systemu.

2. Model ról i uprawnień

System Compass oparty jest na czterowarstwowym modelu uprawnień. Każda rola posiada ściśle zdefiniowany zakres dostępu i możliwości operacyjnych.

2.1. Podsumowanie ról

Rola	Rejestracja	Kluczowe uprawnienia	MFA
Konsultant	Samodzielna	Dostęp do własnego profilu	Nie
Team Lead	Nadawana przez Centrale	Podgląd profili przypisanych konsultantów (tylko odczyt)	Nie
Centrala	Adres wpisany przez Administratora	Zarządzanie kontami konsultantów, pełne uprawnienia operacyjne	Tak (e-mail)
Administrator	Lista w bazie danych	Uprawnienia Centrali + zarządzanie listą Centrali	Tak (e-mail)

2.2. Konsultant

Opis: Podstawowa rola w systemie. Konsultant rejestruje się samodzielnie i posiada dostęp wyłącznie do własnego profilu.

Rejestracja

- Dostępna wyłącznie dla adresów e-mail z domeny @b2bnetwork.pl
- Wymagane dane: imię, nazwisko, adres e-mail, hasło
- Obowiązkowa akceptacja klauzuli RODO przy rejestracji
- Walidacja domeny e-mail po stronie serwera (nie tylko front-end)

Uprawnienia

- Podgląd i edycja własnego profilu
- Brak dostępu do profili innych użytkowników
- Brak dostępu do panelu administracyjnego

2.3. Team Lead

Opis: Rola przygotowana architektonicznie, wdrozenie w przyszłości. Rozszerza uprawnienia Konsultanta o podgląd profili przypisanych podopiecznych.

Przypisywanie

- Centrala przypisuje Konsultantów do Team Leada
- Team Lead nie może samodzielnie dodawać/usuwać podopiecznych

Uprawnienia

- Wszystkie uprawnienia Konsultanta
- Podgląd profili przypisanych konsultantów (tylko odczyt)
- Brak możliwości edycji lub zmiany danych podopiecznych

Status wdrożenia

Faza 1 (obecna): Rola zdefiniowana w strukturze bazy danych, interfejs nieaktywny.

Faza 2 (przyszła): Aktywacja interfejsu, pełna funkcjonalność.

2.4. Centrala (dawna rola Admin)

Opis: Rola operacyjna z pełnym dostępem do zarządzania kontami konsultantów i danymi systemu. Zastępuje dotychczasową rolę Admin.

Nadawanie uprawnień

- Administrator wpisuje adresy e-mail uprawnionych osób w module Ustawienia
- Osoba logująca się z adresem obecnym na liście automatycznie otrzymuje uprawnienia Centrali
- Wylacznie adresy z domeny @b2bnetwork.pl

Uprawnienia

- Pełny dostęp do profili wszystkich konsultantów
- Blokowanie i odblokowywanie kont konsultantów
- Usuwanie kont konsultantów (np. po odejściu z firmy)
- Przypisywanie konsultantów do Team Leadów
- Podgląd logów audytowych
- MFA obowiązkowe (kod e-mail)

2.5. Administrator

Opis: Najwyższy poziom uprawnień w systemie. Posiada wszystkie uprawnienia Centrali oraz wyłączne prawo do zarządzania listą osób z uprawnieniami Centrali.

Lista Administratorów

Lista przechowywana w bazie danych. Adresy e-mail Administratorów:

Adres e-mail	Uprawnienia specjalne
zbigniew.twardowski@b2bnetwork.pl	Master Admin - jedyny może zmieniać listę Administratorów
igor.twardowski@b2bnetwork.pl	Drugi Master Admin - może zmieniać listę Administratorów
artur.twardowski@b2bnetwork.pl	Administrator standardowy
marta.kozarzewska@b2bnetwork.pl	Administrator standardowy

Uprawnienia dodatkowe (względem Centrali)

- Dodawanie i usuwanie osób z listy Centrali (wszyscy Administratorzy)
- Modyfikacja listy Administratorów (wyłącznie Master Admini: zbigniew.twardowski@b2bnetwork.pl oraz igor.twardowski@b2bnetwork.pl)

3. Mechanizmy bezpieczeństwa

3.1. Polityka hasel

Parametr	Wartosc
Minimalna dlugosc	10 znakow
Wymagana wielka litera	Tak (min. 1)
Wymagana cyfra	Tak (min. 1)
Dotyczy rol	Wszystkie

3.2. Uwierzytelnianie wieloskladnikowe (MFA)

MFA jest obowiazkowe dla rol Centrala i Administrator. Metoda: kod weryfikacyjny wysylany na adres e-mail przypisany do konta.

Rola	MFA wymagane	Metoda
Konsultant	Nie	-
Team Lead	Nie	-
Centrala	Tak	Kod e-mail
Administrator	Tak	Kod e-mail

3.3. Ochrona przed atakami brute-force

- Maksymalnie 5 prob logowania w ciagu 15 minut na adres e-mail
- Po 3 nieudanych probach: wyswietlenie CAPTCHA
- Po 5 nieudanych probach: tymczasowa blokada konta na 15 minut
- Kazda nieudana proba logowania rejestrowana w logu audytowym

3.4. Zarzadzanie sesjami

- Automatyczne wylogowanie po 30 minutach nieaktywnosci
- Sesja odnawiana przy kazdej aktywnosci uzytkownika
- Bezpieczne przechowywanie tokenu sesji (httpOnly, secure, SameSite)

3.5. Odzyskiwanie hasla

Mechanizm resetu hasla dostepny dla wszystkich rol:

1. Uzytkownik klika "Nie pamietam hasla" na ekranie logowania
2. System weryfikuje, czy adres e-mail istnieje w bazie
3. Wyslanie linku resetujacego na zarejestrowany adres e-mail

4. Link ważny przez 15 minut, jednorazowy
5. Użytkownik ustawia nowe hasło (zgodne z polityką haseł)
6. System potwierdza zmianę i loguje zdarzenie w audit trail

4. Zarządzanie cyklem życia kont

4.1. Tworzenie kont

Rola	Sposob tworzenia	Kto tworzy
Konsultant	Samodzielna rejestracja z domeny @b2bnetwork.pl	Sam uzytkownik
Team Lead	Awans istniejacego Konsultanta przez Centrale	Centrala
Centrala	Wpisanie adresu e-mail przez Administratora	Administrator (w Ustawieniach)
Administrator	Wpis w bazie danych	Master Admin

4.2. Blokowanie i usuwanie kont

- Centrala moze blokowac, odblokowywac i usuwac konta Konsultantow
- Blokada konta uniemozliwia logowanie, ale nie usuwa danych z systemu
- Usuwanie konta jest operacja trwala (po odejsciu konsultanta z B2B.net)
- Kazda operacja blokowania/usuwania jest rejestrowana w logu audytowym z informacja: kto, kiedy, na czym koncie

4.3. Hierarchia zarzadzania

Schemat zarzadzania kontami:

- Master Admin (zbigniew.twardowski / igor.twardowski) -> zaradza lista Administratorow
- Administrator -> zaradza lista Centrali
- Centrala -> zaradza kontami Konsultantow i Team Leadow
- Team Lead -> brak uprawnień zarzadczych (tylko podglad)
- Konsultant -> brak uprawnień zarzadczych

5. Audit trail i logowanie zdarzen

5.1. Logowanie dostępu (wszystkie role)

Dla kazdego logowania system rejestruje:

- Adres e-mail uzytkownika
- Data i godzina logowania
- Adres IP
- Status (udane / nieudane)
- Przyczyna niepowodzenia (bledne haslo, zablokowane konto, itp.)

5.2. Logowanie akcji (Centrala i Administrator)

Dla kazdej operacji administracyjnej system rejestruje:

- Kto wykonal akcje (adres e-mail operatora)
- Jaka akcje wykonano (typ operacji)
- Kiedy (data i godzina)
- Na czym koncie (adres e-mail docelowy)
- Szczegoly zmiany (np. zmiana roli, blokada konta)

5.3. Typy operacji do logowania

Operacja	Wykonawca	Logowane dane
Logowanie	Wszyscy	IP, czas, status
Reset hasla	Wszyscy	Adres, czas, IP
Blokada konta	Centrala	Operator, cel, czas
Usuniecie konta	Centrala	Operator, cel, czas
Dodanie do Centrali	Administrator	Operator, nowy adres, czas
Usuniecie z Centrali	Administrator	Operator, adres, czas
Zmiana listy Adminow	Master Admin	Operator, zmiana, czas
Przypisanie do TL	Centrala	Operator, konsultant, TL, czas

6. Przepływ procesu logowania

6.1. Rejestracja Konsultanta

1. Użytkownik otwiera formularz rejestracji
2. Wpisuje adres e-mail - system waliduje domene @b2bnetwork.pl
3. Wpisuje imię i nazwisko
4. Ustawia hasło (min. 10 znaków, wielka litera, cyfra)
5. Akceptuje klauzule RODO (checkbox obowiązkowy)
6. System tworzy konto z rolą Konsultant
7. Użytkownik może się zalogować

6.2. Logowanie Konsultanta / Team Leada

1. Użytkownik wpisuje adres e-mail i hasło
2. System weryfikuje dane logowania
3. Po poprawnej weryfikacji - przekierowanie do profilu
4. Po nieudanej próbie - komunikat błędu, licznik prób +1

6.3. Logowanie Centrali / Administratora

1. Użytkownik wpisuje adres e-mail i hasło
2. System weryfikuje dane logowania
3. Po poprawnej weryfikacji - system wysyła kod MFA na adres e-mail
4. Użytkownik wpisuje kod MFA
5. Po poprawnej weryfikacji kodu - przekierowanie do panelu

7. Procedury awaryjne

7.1. Niedostępność Master Admina

W systemie zdefiniowani są dwaj Master Admini:

- zbigniew.twardowski@b2bnetwork.pl (Master Admin 1)
- igor.twardowski@b2bnetwork.pl (Master Admin 2)

W przypadku niedostępności jednego z nich, drugi Master Admin przejmuje pełną kontrolę nad zarządzaniem listą Administratorów.

7.2. Kompromitacja konta Administratora

W przypadku podejrzenia kompromitacji konta Administratora:

1. Natychmiastowa zmiana hasła przez właściciela konta
2. Master Admin może usunąć skompromitowane konto z listy Administratorów
3. Przegląd logów audytowych w celu identyfikacji nieautoryzowanych akcji

7.3. Awaria systemu MFA

W przypadku awarii systemu wysyłki kodów MFA, osoby z rolami Centrala i Administrator nie będą mogły się zalogować. Procedura awaryjna: bezpośredni kontakt z zespołem DevOps w celu tymczasowego wyłączenia MFA z jednoczesnym logowaniem tego zdarzenia.

8. Wymagania techniczne (podsumowanie)

Komponent	Wymaganie
Baza danych	Tabele: users, roles, admin_list, centrala_list, team_lead_assignments, audit_log, login_log
Walidacja domeny	Server-side: tylko @b2bnetwork.pl dla rejestracji i wszystkich rol
Hashowanie hasel	bcrypt lub Argon2 (NIE MD5, NIE SHA)
Sesje	Timeout 30 min nieaktywnosci, tokeny httpOnly/secure/SameSite
MFA	Kod e-mail, waznosc 5 min, jednorazowy
Rate limiting	5 prob / 15 min per adres, CAPTCHA po 3 probach
Reset hasla	Link jednorazowy, waznosc 15 min
Audit trail	Logowanie logow. i akcji admin., retencja min. 12 miesiecy
RODO	Checkbox akceptacji przy rejestracji, przechowywanie zgody

9. Historia dokumentu

Wersja	Data	Autor	Opis zmian
1.0	17.02.2026	Zbigniew Twardowski	Wersja poczatkowa specyfikacji

Zatwierdzil:

Data: